

Fundamentos de Criptografia e Segurança da Informação

Licenciatura em Matemática e Ciências da Computação
(3ºano, 2º sem.)

José Bacelar Almeida

Criptografia

Criptografia Simétrica

Criptografia Assimétrica

Aplicações

Conteúdo

- Infraestrutura de Chave Pública (PKI)
 - Certificados X509
- Protocolos Criptográficos
 - TLS
- Assinatura de Documentos
 - PADES
 - Assinatura Qualificada
- Tokens Criptográficos
 - Cartão de Identificação (EU)
 - EUIDW

Infraestrutura de Chave Pública (PKI)

Standards de Certificação

- O uso generalizado de certificados de chave pública requer uma base sólida para seu estabelecimento e sistematização:
 - Formatos e tecnologias;
 - Convenções e assumpções;
 - Práticas e procedimentos;
 - Estrutura regulatória e jurídica;
 - Etc.
- De fato, um PKI preenche a lacuna entre conceitos e elementos de natureza tecnológica (chaves criptográficas) e aspectos que são, em última análise, sociais (identidade; individualidade; personalidade).

Infraestrutura de Chave Pública (PKI)

A **Infraestrutura de Chave Pública (PKI)** ié um conjunto de funções, políticas, hardware, software e procedimentos necessários para criar, gerenciar, distribuir, usar, armazenar e revogar **certificados digitais**.

- É uma área que se desenvolveu em grande medida em resposta a estímulos localizados e soluções bem-sucedidas para problemas específicos que, uma vez suficientemente maduros, foram adotados noutros domínios.
 - X509 foi a primeira tentativa bem-sucedida de padronizar certificados de chave pública (ITU-1998) como o mecanismo de autenticação para o standard X500 (Directory Services).
 - Esses certificados foram posteriormente adotados para o protocolo SSL para proteger conexões HTTP(S) (*Netscape SSLv2* — 1995).
 - O IETF-PKIX-WG foi instituído (em 1995-2013) para promover o desenvolvimento de padrões técnicos (RFCs) para apoiar a PKI com base em certificados X509.

PKIX

- Diferentes entidades envolvidas na PKI:
 - **Detentores de Certificados (subjects)**: quem solicita a certificação de sua chave pública;
 - **Clientes**: quem utiliza as chave pública contida nos certificados;
 - **Autoridades de Certificação (CAs)**: entidades responsáveis na emissão/renovação/revogação de certificados.
 - **Autoridades de Registo (RAs)**: entidades responsáveis pelo estabelecimento da associação entre chaves públicas e identidades dos titulares (opcional).
 - **Repositórios**: armazenar e disponibilizar certificados e outra informação relevantes (como certificados revogados, etc.).
- PKIX define um conjunto de especificações e protocolos que permitem
 - protocolos operacionais — sistemas/aplicações que possibilitam e justificam a confiança na utilização de certificados X509
 - gestão da PKI — pperações (inicialização; ciclo de vida do certificado; distribuição); políticas; melhores práticas; etc.

Certificados X509

- Os certificados X509 incluem:
 - Conteúdo informativo:
 - **subject** (i.e. identidade de quem detém a chave privada associada à chave pública certificada);
 - A **chave pública** do titular;
 - A identificação do **emissor** (CA);
 - Outras informações relevantes (número de série; período de validade; extensões; etc.)
 - **Assinatura** de todo o conteúdo pela CA.
- Os dados são representados como uma estrutura de dados de atributo/valor (dicionário).
- A codificação desses dados é padronizada, garantindo a interoperabilidade.
 - **DER** - formato binário definido pelo standard (notação ASN.1)
 - **PEM** - apresentação das informações contidas no formato DER em caracteres imprimíveis.
- O certificado é assinado pela Autoridade de Certificação (CA), assinatura essa sobre a codificação DER dos dados informativos que estes contém.

Certificados X.509v3

- Certificados atualmente em uso (X509v3 — 1996) supriram deficiências de versões anteriores em alguns domínios de aplicação (falta de atributos).
- Esta versão introduziu um campo de **Extensões**, equipando assim os certificados com a flexibilidade necessária, permitindo que atributos genéricos sejam associados ao titular ou à sua chave pública.
- Cada extensão é em si uma estrutura de dados com um identificador e um valor apropriado ao tipo de atributo que ela representa.
- As extensões são marcadas como **Critical** ou **Non Critical**. Uma aplicação que encontra uma extensão crítica que não reconhece deve rejeitar o certificado.

Estrutura do certificado

- Atributos básicos
 - **version** - Versão do padrão X509 (v3).
 - **serialNumber** - Número único atribuído pelo CA ao certificado.
 - **subject** - Identificação do titular da chave pública contida no certificado.
 - **subjectPublicKeyInfo** - Estrutura contendo a chave pública do titular do certificado e identificação do algoritmo correspondente.
 - **issuer** - Identificação da CA que emite o certificado.
 - **signature** - Estrutura que identifica o algoritmo usado para gerar a assinatura da CA contida no certificado.
 - **validity** - Estrutura contendo duas datas que delimitam o período de validade do certificado.
- Extensions (selected)
 - **basicConstraints** - sinaliza se o titular é uma (sub-)CA (e, opcionalmente, um limite ao tamanho do caminho de certificação);
 - **keyUsage** - restringe os usos do par de chaves associado ao certificado;
 - ...

Verificação de Certificados e Cadeias de certificação

- Certificados são objetos assinados, pelo que podem ser transmitidos em canais abertos.
- É claro que o uso adequado de certificados implica a verificação da sua assinatura, o que, por sua vez, implica conhecer a chave pública da CA emissora. Existem duas opções:
 1. A chave pública já é conhecida pelo usuário (por exemplo, foi pré-instalada com segurança);
 - 2....ou é fornecido por outro certificado (emitido por outra CA).
- Naturalmente, no segundo caso, a validade do novo certificado precisa ser verificada, o que resulta em um **procedimento de validação recursiva**.
- A sequência de certificados envolvidos na verificação é designada por **cadeia de certificados**.

Validação de Certificados

- Para cada certificado numa cadeia de certificação bem formada, deve-se verificar:
 - Assinatura do certificado;
 - a aplicabilidade do certificado (por exemplo, se não expirou; se o uso está de acordo com seus atributos; etc.);
 - (não foi revogado)
- A raiz da cadeia de certificação deve ser de uma CA cuja chave pública já é conhecida — isso é conhecido como **âncora de confiança** (raiz da relação de confiança).
- Por convenção, os **certificados raiz** são **autoassinados** (*subject é o issuer*).

Âncoras de Confiança (Trust anchors)

- Um utilizadores conhece um número limitado de chaves públicas de CAs (geralmente CAs Root), e que atuam como as raízes na relação de confiança.
- A **gestão da lista de âncoras confiáveis** é normalmente realizado pelo sistema operativo.
- Em particular, a escolha e actualização de certificados raiz é normalmente assegurada pelo fabricante do sistema operativo.
- Isso torna o processo de uso de certificados mais transparente para o utilizador final.
 - **O que é bom!**, porque tanto os conceitos como o manuseamento dos certificados é complexo.
 - **O que é mau!**, porque não há consciência (responsabilização) das relações de confiança envolvidas.

Revogação de Certificados

- Às vezes, há a necessidade de revogar certificados que ainda são válidos.
- Possíveis razões para a revogação:
 - Chave privada comprometida;
 - A circunstância que justificou a associação do emissor com a chave pública deixou de existir (por exemplo, o emissor é o titular de uma posição temporária).
 - Os dados contidos no certificado deixam de ser corretos (por exemplo, um atributo deixa de se aplicar)
 - Etc.
- O mecanismo original para revogar certificados são as **Certificate Revocation List (CRL)** — uma lista assinada de certificados revogados pela CA, para que devem ser consultados durante a verificação de certificados (o ponto de distribuição CRL, se aplicável, está incluído no certificado).
- Mas as deficiências da CRL recomendam o uso de mecanismos de verificação *online* — **Online Certificate Status Protocol (OCSP)**.

Protocolos Criptográficos

Protocolos de Comunicação Segura

- Vários protocolos permitem o estabelecimento de um **canal seguro** — um canal de comunicação garantindo:
 - Integridade dos dados;
 - Autenticação de Entidade (do servidor ou autenticação mútua);
 - Confidencialidade (opcional).
- Esses protocolos atuam em diferentes níveis no modelo OSI: por exemplo.
 - network layer (IPSec, VPNs);
 - transport layer (TLS);
 - application layer (SSH; S/MIME; PGP)

Typical structure

- Protocolos de comunicação seguros normalmente incluem duas fases:
 1. **Handshake** (ou gestão de chaves) — negociar parâmetros; algoritmos criptográficos e chaves para configurar o canal de comunicação seguro;
 2. **Secure communication link** — realiza o canal seguro usando criptografia simétrica.
- A criptografia assimétrica geralmente desempenha o seu papel apenas na primeira fase.
- Ocasionalmente, a fase de *handshake* pode ser repetida/renovada (e.g. rekeying).

IPsec

- IP (Internet Protocol) opera na camada de rede do modelo OSI. Fornece serviços de encaminhamento de pacotes em redes heterogêneas.
- IPSec está incluído no IPv6, sendo opcional no IPv4.
- IPsec complementa IP ao adicionar funcionalidade de segurança. Em concreto:
 - Serviços de integridade ao nível do pacote, garantindo a autenticidade de origem dos dados e, opcionalmente, protecção contra repetição de pacotes — **authentication header (AH)**;
 - Confidencialidade de todo ao parte do tráfego — **Encapsulating Security Payload (ESP)**.
- Esses serviços, sendo oferecidos na camada de rede, fornecem não apenas protecção nesse nível, mas também em todas as camadas acima.

TLS

- Originalmente concebido por *Netscape inc.* como **Secure Sockets Layer (SSL)**.
- É para o TCP o que o IPsec é para o IP — é uma atualização da camada de transporte para incluir segurança nas comunicações.
- SSL v3 foi adotado pela IETF sob o nome **Transport Layer Security (TLS)**.
- SSL/TLS suporta os seguintes modos de autenticação:
 - **server authentication** - Modo normalmente adotado em cenários web (HTTPS) — o servidor certifica sua identidade por meio de uma assinatura e usando um certificado X509 com atributos apropriados.
 - **mutual authentication** - o servidor também solicita que o cliente se autentique criptograficamente, exigindo que ele disponha de um certificado apropriado.

Segurança do TLS

- Mesmo que a versão actual do protocolo TLS seja considerada segura, a verdade é que o histórico de ataques que a família de protocolos SSL/TLS enfrentou nos últimos anos é embaraçoso (consulte https://en.wikipedia.org/wiki/Transport_Layer_Security#Attacks_against_TLS.2FSSL).
- Em geral, os ataques direcionados ao próprio protocolo foram superados por revisões sucessivas (por exemplo, "ciphersuite roolback", possível na versão SSL.2, foi superado com a autenticação de mensagens de handshake exigidas pelo SSL.3).
- Os ataques mais recentes ao SSL/TLS são direcionados principalmente a:
 - Aspectos de implementação menos cuidados ou recursos obscuros do protocolo (por exemplo, como no *Heartbleed attack*);
 - Interação com conjuntos de criptografia específicos (por exemplo, uso de RC4 ou *padding oracle attack* no modo CBC).
- Na prática, o grande número de opções de configuração requer muito cuidado no *deployment* (ver <https://ssllabs.com>).

TLS 1.3

- A versão atual do protocolo TLS (v1.3) concluiu recentemente sua fase final de padronização ([RFC-8446](#)).
 - Consiste em uma redefinição substancial do protocolo:
 - Deixa de ser compatível com versões anteriores;
 - Tem como objetivo alcançar maior eficiência e maior segurança (vs. TLS1.2).
- Alguns aspectos:
 - Simplifica handshake (1 roundtrip).
 - Remove o suporte para requisitos "obscuros" ou pouco usados; técnicas criptográficas obsoletas (e.g. (3)DES, RC4, MD5, SHA-1, AES-CBC, ...); etc.
 - Opta por suportar apenas um conjunto restrito de possibilidades (DHE groups; AEAD modes; ...)

Assinatura de Mensagens/ Documentos

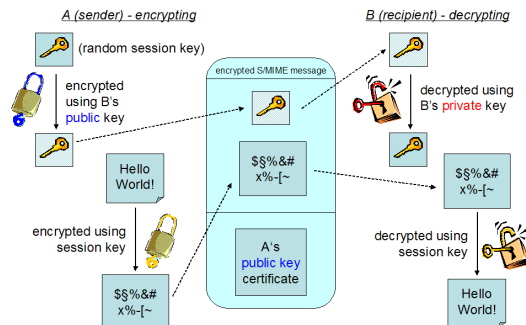
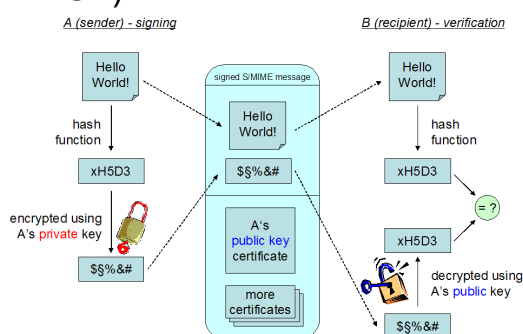
Segurança no EMail

- O uso generalizado do e-mail o torna uma área natural para recorrer à criptografia para melhorar sua segurança.
- Ele fornece combinações dos seguintes serviços de segurança:
 - **autenticidade, integridade and não-repúdio** da origem das mensagens através do uso de assinaturas digitais;
 - **confidencialidade da mensagem** através do uso de criptografia de chave pública (mais precisamente, do envelope digital).
- As primeiras instâncias de sistemas de e-mail seguros foram alvo de problemas legais consideráveis (especificamente, PGP)...
- ...tornando-o um porta estandarte na promoção da privacidade online.

S/MIME

Secure/Multipurpose Internet Mail Extensions

- S/MIME oferece uma forma consistente de enviar e receber informações seguras no formato MIME.
- Depende de certificados X509 e PKIX para autenticar chaves públicas.
- Suportado pela maioria das aplicações de e-mail existentes (Mail User Agents — MUA).



PGP

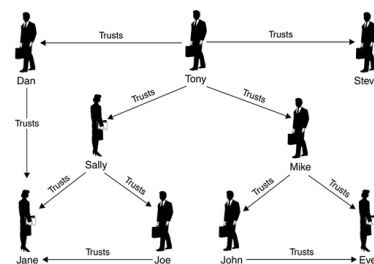
Pretty Good Privacy

- PGP é uma aplicação freeware desenvolvido por *Phil Zimmermann* (1991) com o objetivo de disponibilizar uma infraestrutura para proteger a informação (e privacidade) para cidadãos comuns.
- Controvérsia nos EUA devido às leis de restrições à exportação da designada criptografia forte. A batalha legal associada foi um marco importante no equilíbrio entre a privacidade individual e a segurança nacional.

"if information protection is outlawed, only outlaws can have privacy!"

- Tecnicamente, a característica mais saliente (e original) foi sua abordagem à certificação de chaves públicas: a web-of-trust.

- Evita a dependência de uma hierarquia de confiança rígida (como na PKIX);
- Imita os padrões de interação social;
- Cada utilizador pode certificar as chaves públicas de outros;
- ...e escolher confiar noutros nessa tarefa.

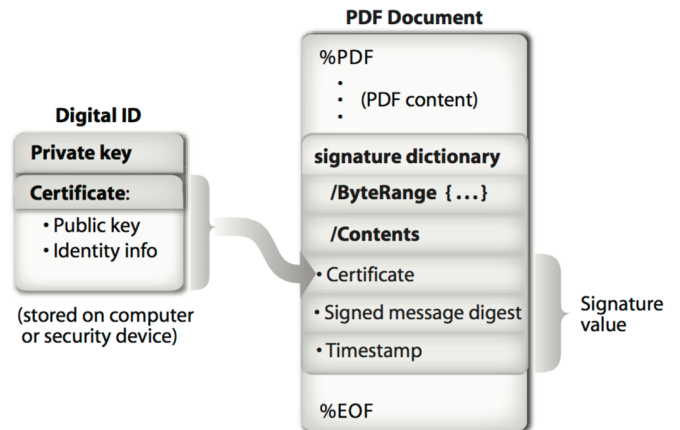


Assinatura de Documentos

- Uma aplicação imediata de assinaturas digitais é para certificar a origem dos documentos.
- Os legisladores têm prestado atenção a este domínio, dando-lhe um enquadramento legal.
- Independentemente dos detalhes criptográficos e do enquadramento legal, podemos afirmar que a segurança das assinaturas digitais depende de:
 1. A segurança dos algoritmos de criptográficos envolvidos e sua implementação;
 2. Garantias que a chave privada é verdadeiramente secreta;
 3. O detentor legítimo da chave pública pode ser verificado;
 4. Utilizadores e Software realizam corretamente o protocolo de assinatura/verificação.

PAdES

- PDF é um dos formatos mais usados para suportar documentos digitais.
- Originalmente de uma empresa privada (Adobe), desde então foi padronizado por organismos internacionais (ISO 32000-1, 32000-2).
- Inclui suporte para assinaturas digitais (desde a V1.7), permitindo o acesso ao recurso usando aplicações disponíveis gratuitamente (e.g. Acrobat Reader).
- Versões mais recentes atualizaram o suporte para assinaturas digitais para alinharem com o **PAdES — PDF Advanced Electronic Signatures** standard (ETSI).
- PAdES é um padrão técnico que alinha assinaturas digitais em PDF com o **regulamento eIDAS da UE**.



Qualified Electronic Signature (QES)

- Ao assinar documentos, uma Assinatura Qualificada é de particular relevância no contexto europeu (eIDAS).
- Uma **Assinatura Electrónica Qualificada (Qualified Electronic Signature — QES)** é uma assinatura digital na qual:
 1. A identidade do signatário é atestada por um **Certificado Qualificado**;
 2. Criado por um dispositivo eletrônico seguro.
- A noção de Certificado Qualificado impõe requisitos rigorosos às CAs que os emitem (Certification Service Providers — CSP).
- Em particular, cada estado membro é responsável por credenciar CSPs com capacidade de emitir certificados qualificados (válidos em todos os estados membros da UE).

Trusted Timestamping

- **Timestamping** é o processo que permite certificar o tempo de criação e/ou modificação de um documento.
- Um *trusted timestamp* é emitido por um **Trusted Third Party (TTP)** actuando como **Time Stamping Authority (TSA)**.
- Criptograficamente, consiste em uma assinatura que liga o conteúdo do documento (seu hash) e um “selo” de data/hora obtido de uma fonte confiável.
- Quando usado em assinaturas digitais, ele estabelece o tempo de criação da assinatura (importante, por exemplo, para verificar a validade do certificado naquele momento).
- *Timestamping* é um dos **trust services** incluído no regulamento eIDAS.
- Assim, um **Qualified Timestamp** emitido num estado membro de UE é válido e reconhecido em qualquer estado membro.

Timestamp Service Timestamping Authority (TSA)

